Oopsie

Plataforma: HackTheBox

Dificuldade: FÁCIL

Data de Resolução: 19/04/2026

Pedro Avila Beneveli

Sumário

1 Visão Geral **2**

2 Reconhecimento **2**

3 Exploração **3**

3.1 Reverse Shell 3

4 Movimentação Lateral **4**

5 Escalada de Privilégios **4**

6 Conclusão **5**

7 Referências **5**

1 Visão Geral

O presente desafio consiste na exploração e infiltração de um serviço web mal confirgurado. Encontradas as portas expostas, realiza-se uma análise das requisições feitas ao servidor e abusa-se de informações e funcionalidades mal configuradas para conseguir um acesso à máquina.

Depois disso, explora-se credenciais expostas para acessar à máquina por meio do SSH, e explora-se um binário com permissões indevidas para conseguir um acesso de leitura a qualquer arquivo na máquina.

2 Reconhecimento

Primeiramente, foi utilizado o nmap para identificar os serviços expostos na máquina alvo.

Listing 1: Varredura inicial com Nmap

```
nmap <TARGET_IP> -sV
```

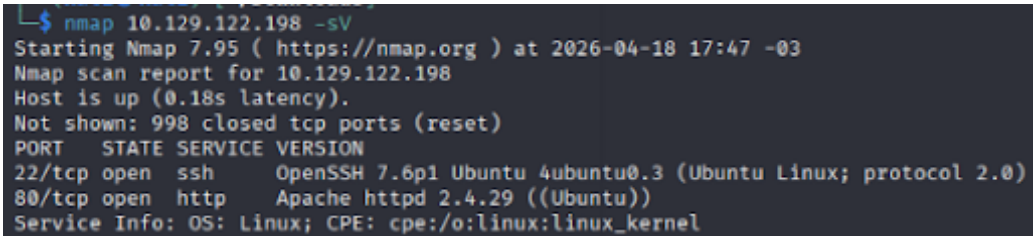

Figura 1: Resultado do nmap.

Como observado na Figura 1 foi identificado o serviço SSH na porta 22, que poderá ser utilizado futuramente caso encontremos algum usuário e senha, e HTTP na porta 80.

Depois disso, acessamos o serviço HTTP por meio do navegador, na qual encontramos uma página web, que não possuem encaminhamentos para outras páginas. Paralelamente, realizei uma buster de diretórios, com os resultados na Figura 2.

Listing 2: Buster de diretórios com gobuster

```
 gobuster dir -u http://<TARGET_IP> -w /usr/share/wordlists/dirbuster/
directory-list-2.3-small.txt -x php,html,txt,go
```

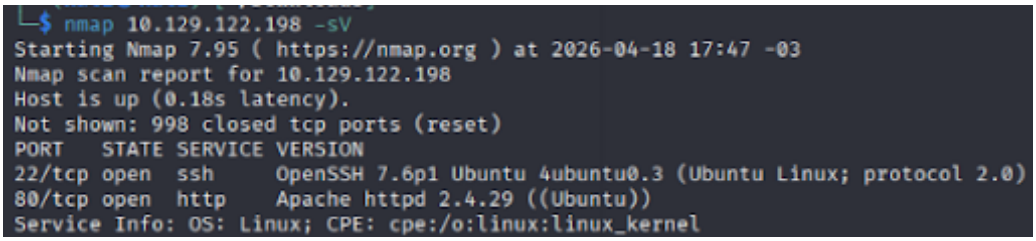

Figura 2: Resultado do gobuster.

Como nenhum novo diretório relevante foi encontrado, foi feita uma busca em elementos dessa página, inicialmente pelo html da página. Não encontrando nada muito relevante, olhei a aba "Network"do navegador, para visualizar as requisições realizadas. Nessa página, encontrei uma requisição de algo de javascript para uma página cdn-cgi/login. Ainda mais, rodei o gobuster da seguinte forma no novo diretório:

```
Starting gobuster in directory enumeration mode
/index.php            (Status: 200) [Size: 4735]
/admin.php            (Status: 302) [Size: 0] [--> /cdn-cgi/login/index.php]
/db.php               (Status: 200) [Size: 0]
Progress: 106526 / 438315 (24.30%)^C
```

Figura 3: Resultado do gobuster no diretório cdn-cgi/login.

```
gobuster dir -u http://<TARGET_IP>/cdn-cgi/login -w /usr/share/
wordlists/dirbuster/directory-list-2.3-small.txt -x php,html,txt,go
```

Com os resultados presentes na Figura 3 Como esse diretório é igual ao passo indicado pelo HackTheBox, segui na exploração dessa página de login.

3 Exploração

Descrição técnica do vetor de entrada. Explique o raciocínio por trás da identificação da falha.

Na página cdn-cgi/login, conseguimos acessar a próxima página ao realizar login como visitante. Das abas encontradas, uma levantou maior interesse: a de uploads. Porém, nosso usuário não consegue acessar essa página, sendo necessária uma permissão de admin. Daí vem uma outra página de interesse: a de usuário, que mostra o nome do usuário e o id de acesso daquele usuário.

Na URL dessa página, podemos observar que há uma parte relacionada com id:

```
http://<TARGET_IP>/cdn-cgi/login/admin.php?content=accounts&id=2
```

Trocando esse id para 1, observamos que aparece o id de acesso e o nome de um usuário chamado 'admin'. Com esses valores, conseguimos trocar o cookie de role pra admin e do user para o valor encontrado.

Conseguindo acessar a página como administrados, agora temos acesso à página de uploads. Com base no buster de diretórios feito no Reconhecimento, podemos ver na Figura 2 que há um diretório base chamado uploads. Para ver se conseguimos acessar algum arquivo nessa pasta, subi um arquivo teste.html:

```
<p>Testando, oi oi</p>
```

Acessando o endereço *<TARGET_IP>/uploads/teste.html*, a página html é exibida, mostrando que não apenas conseguimos acessar os arquivos que realizamos upload. Isso abre a possibilidade de conseguir uma shell reversa a partir de um arquivo .php.

3.1 Reverse Shell

O arquivo utilizado é o do Pentestmonkey [1]. Para utilizá-lo, realizamos o upload do arquivo disponibilizado, trocando no arquivo o IP para o IP de nossa máquina e definindo a porta que usaremos. Depois disso, rodamos o seguinte comando com o *netcat* para preparmos para receber a shell reversa:

```
nc -l -p <PORT>
```

Por fim, executamos o arquivo a partir da URL *<TARGET_IP>/uploads/php-reverse-shell.php*. Com isso, conseguimos uma shell na máquina alvo, permitindo que avançar no desafio.

4 Movimentação Lateral

Com acesso à máquina alvo, primeiro decidi verificar um arquivo suspeito encontrado ao rodar o gobuster anteriormente, o arquivo *db.php*, como observamos na Figura 3. Ao abrirmos esse arquivo, encontramos um usuário, 'robert', e uma sequência de letras e números.

```
<?php
$conn = mysqli_connect(localhost,robert,<PASSWORD>,garage);
?>
```

Ao tentarmos acessar o SSH com essa sequência como senha, conseguimos acessar a máquina como esse usuário.

```
ssh robert@<TARGET_IP>
```

Já na pasta home desse usuário, já encontramos a flag de usuário:

```
$ robert@oopsie:~$ ls
user.txt
$ robert@oopsie:~$ cat user.txt
<USER_FLAG>
```

5 Escalada de Privilégios

Para realizar a escalada de privilégios, inicialmente fiz upload do arquivo *linpeas.sh* [2] para a máquina utilizando o safe copy, utilizando a senha encontrada anteriormente:

```
scp linpeas.sh robert@<TARGET_IP>:/tmp
```

Na máquina alvo, damos acesso ao arquivo e rodamos o linpeas. Ao analisar a saída, encontramos diversas vulnerabilidades em vermelho, mas mais notávelmente a presente na Figura 4.

```
$robert@oopsie:/tmp$ chmod 777 linpeas.sh
$robert@oopsie:/tmp$ ./linpeas.sh
```

Figura 4: Resultado mais notável do linpeas relacionado ao bugtracker.

Dado esse arquivo não familiar, decidi testá-lo para ver como funcionava. Ao executá-lo, ele pede um id, e exibe um texto dado esse id. Como o linpeas deu a dica em relação à permissões root, tentei rodar o /bin/sh como argumento, sem modificações em seu comportamento. Porém, ao tentar abrir o bug de id 5, surgiu um erro do *cat*:

```
cat: /root/reports/5: No such file or directory
```

Portanto, conseguimos determinar 2 coisas dessa mensagem de erro. Primeiramente, o executável bugtracker, por baixo dos panos, executa um cat no arquivo passado como id, a partir do path */root/reports*. Segundo, como o bugtracker está abrindo arquivos na pasta root, ele tem permissão para abrir arquivos nessa pasta.

Dado esses fatos, e como o nome da flag de root usualmente está em um arquivo *root.txt*, rodei o bugtracker, passando como id *../root.txt*, o que revelou a flag de root <ROOT_FLAG>. O processo como um todo pode ser observado na Figura 5.

Adquirida a flag de root, concluímos o desafio.

Figura 5: Processo para adquirir a flag de root.

6 Conclusão

Portanto, podemos observar que o desafio Oopsie testa diversas habilidades necessárias em segurança ofensiva. Ele exige que você procure por informações em pacotes enviados durante as requisições para encontrar diretórios suspeitos, e modificar cookies e URL para conseguir acessar informações e funcionalidades que não deveriam ser disponíveis. Ainda mais, ele utiliza do reverse shell para obter acesso na máquina alvo, e da análise de binários estranhos com permissões não apropriadas para permitir acessarmos arquivos com permissão de usuário.

7 Referências

[1] Pentestmonkey Reverse Shell em PHP

`https://github.com/pentestmonkey/php-reverse-shell/blob/master/php-reverse-shell.php`

[2] Linpeas

`https://linpeas.sh`